Cryptography
An Introduction

Shon Harris

CISSP, 5th Edition

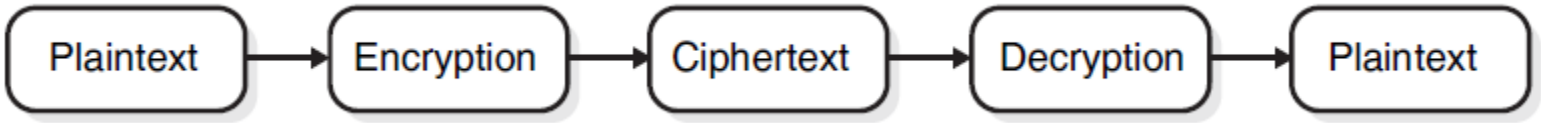


Cryptography
3.1.1 Definitions and Concepts

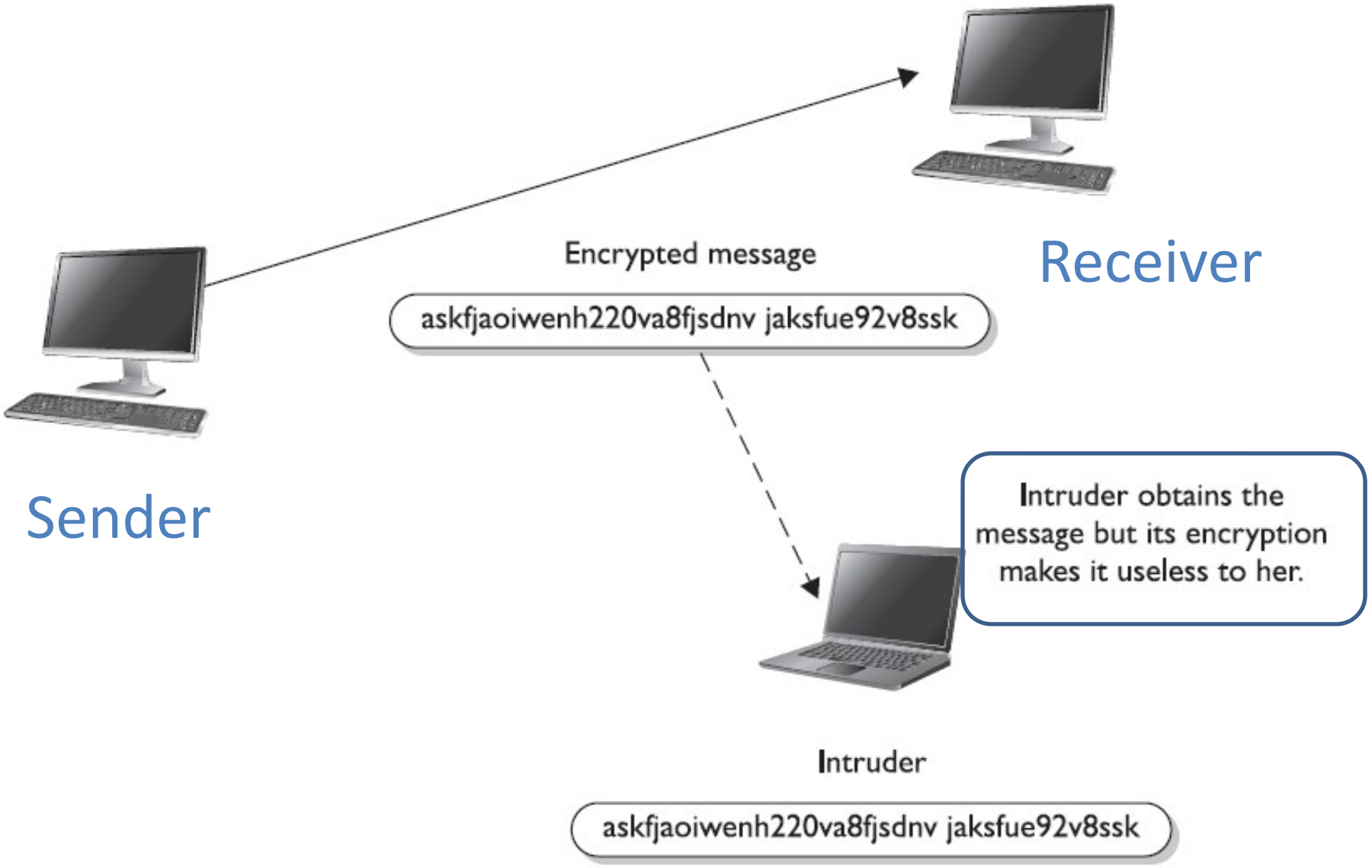
- When data is stored on a computer, it is usually protected by logical and physical access controls
- When this same sensitive information is sent over a network, it can no longer take these controls for granted, and the information is in a much more vulnerable state

Cryptography
Definitions and Concepts

- Encryption is a method of transforming readable data, called ***plaintext,*** into a form that appears to be random and unreadable, which is called ***ciphertext***



- This enables the transmission of confidential information over insecure channels without unauthorized disclosure



Without the right key, the captured message is useless to an attacker.

Cryptography
Definitions and Concepts

- A system or product that provides encryption and decryption is referred to as a ***cryptosystem*** and can be created through hardware components or program code in an application
- The cryptosystem uses an encryption ***algorithm***
- Most ***algorithms*** are complex mathematical formulas that are applied in a specific sequence to the plaintext

Cryptosystems

A cryptosystem encompasses all of the necessary components for encryption and decryption to take place. Pretty Good Privacy (PGP) is just one example of a cryptosystem.

A cryptosystem is made up of at least the following:

- Software
- Protocols
- Algorithms
- Keys

Cryptography
Definitions and Concepts

- Most encryption methods use a secret value called a ***key*** *(usually a long string of bits),* ***which*** *works with the algorithm* ***to*** encrypt and decrypt the text
- The ***algorithm,*** the set of rules also known as the cipher, dictates how enciphering and deciphering takes place
- Many of the mathematical algorithms used in computer systems today are publicly known and are not the secret part of the encryption process

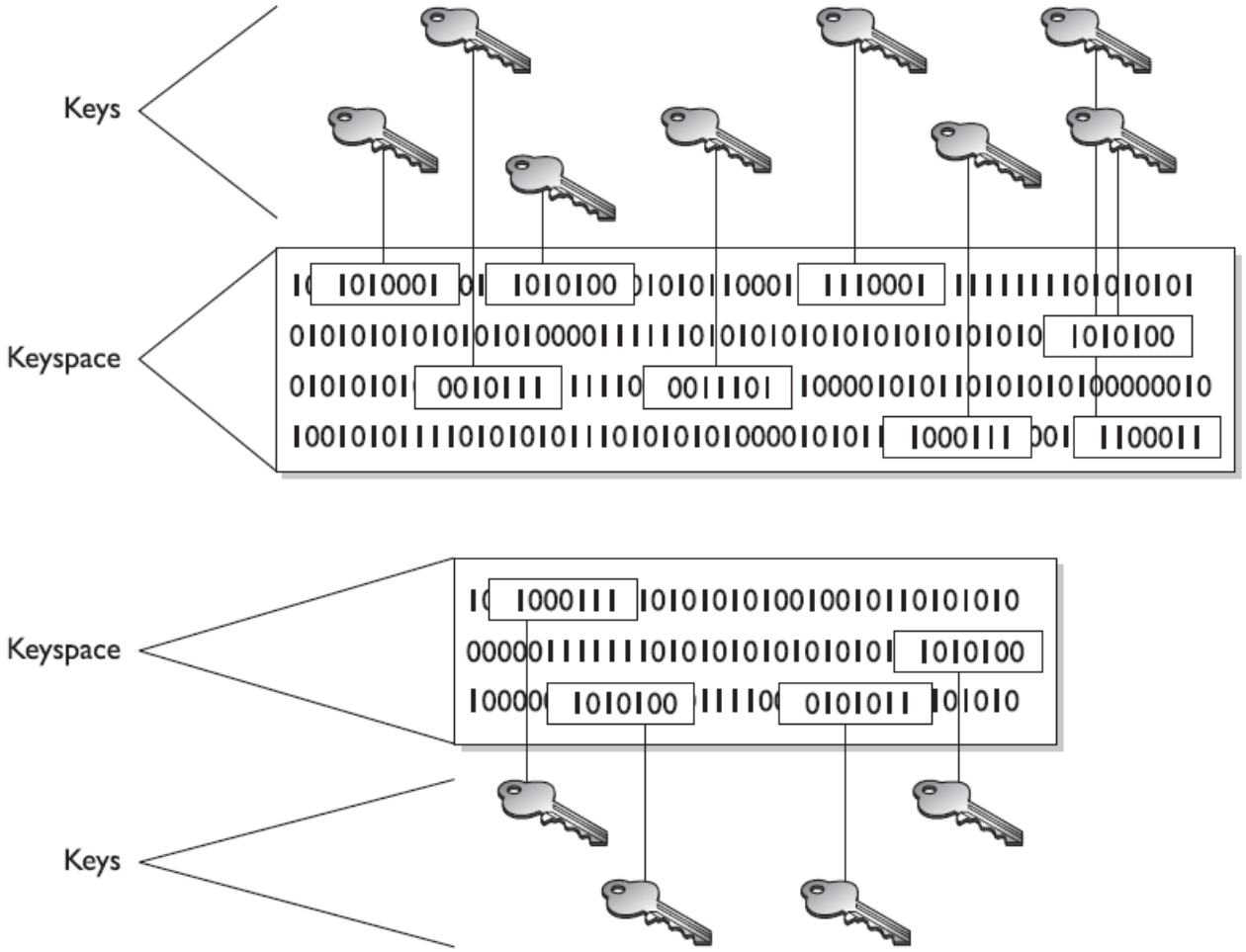
- If the internal mechanisms of the algorithm are not a secret, then something must be
- The secret piece of using a well-known encryption algorithm is the key





Cryptography
Definitions and Concepts

- In encryption, the *key (cryptovariable) is a value that comprises a large sequence of* random bits
- An algorithm contains a *keyspace, which is a range of values that can be used to construct a* key



The larger the keyspace, the more available values can be used to represent different keys—and the more random the keys are, the harder it is for intruders to figure them out

Cryptography
Definitions and Concepts

- When the algorithm needs to generate a new key, it uses random values from this keyspace

For example, if an algorithm allows a key length of 2 bits, the keyspace for that algorithm would be 4, which indicates the total number of different keys that would be possible. That would not be a very large keyspace, and certainly it would not take an attacker very long to find the correct key that was used.

Cryptography
Definitions and Concepts

- A large keyspace allows for more possible keys.
- Today, we are commonly using key sizes of 128, 256, 512, or even 1,024 bits and larger. So a key size of 512 bits would provide a 2^{512} possible combinations (the keyspace)
- The encryption algorithm should use the entire keyspace and choose the values to make up the keys as randomly as possible.

Key Length and Exhaustive Search Time

Key Length in Bits	Number of Possible Keys
1	2
2	4
4	16
8	256
16	65,536
40	1,099,511,627,776
56	72,057,594,037,927,900
112	5,192,296,858,534,830,000,000,000,000,000
112	5.1923E+33
168	3.74144E+50
256	1.15792E+77
512	1.3408E+154

Each extra bit doubles the number of keys



Shaded keys are Strong symmetric keys (>=100 bits)

Raymond R. Panko

Time Required For Decryption

Key Size (bits)	Number of Alternative Keys	Time required at 1 decryption/μs	Time required at 10^6 decryptions/μs
32	$2^{32} = 4.3 \times 10^9$	2^{31} μs = 35.8 minutes	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	2^{55} μs = 1142 years	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	2^{127} μs = 5.4×10^{24} years	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	2^{167} μs = 5.9×10^{36} years	5.9×10^{30} years
26 characters (permutation)	$26! = 4 \times 10^{26}$	2×10^{26} μs = 6.4×10^{12} years	6.4×10^6 years

Major Symmetric Key Encryption Ciphers

	RC4	DES	3DES	AES
Key Length (bits)	40 bits or more	56	112 or 168	128, 192, or 256
Key Strength	Very weak at 40 bits	Weak	Strong	Strong
Processing Requirements	Low	Moderate	High	Low
RAM Requirements	Low	Moderate	Moderate	Low
Remarks	Can use keys of variable length	Created in the 1970s	Applies DES three times with two or three different DES keys	Today's gold standard for symmetric key encryption

Raymond R. Panko

3.1.2 Kerckhoffs' Principle

- Auguste Kerckhoffs published a paper in 1883 stating that the only secrecy involved with a cryptography system should be the key. He claimed that the algorithm should be publicly known.
- He asserted that if security were based on too many secrets, there would be more vulnerabilities to possibly exploit

- Cryptographers in the private and academic sectors agree with Kerckhoffs' principle, because making an algorithm publicly available means that many more people can view the source code, test it, and uncover any type of flaws or weaknesses
- It is the attitude of "many heads are better than one." Once someone uncovers some type of flaw, the developer can fix the issue, and provide society with a much stronger algorithm

- But, not everyone agrees with this philosophy. Governments around the world create their own algorithms that are not released to the public. Their stance is that if a smaller number of people know how the algorithm actually works, then a smaller number of people will know how to possibly break it
- Cryptographers in the private sector do not agree with this practice and do not trust algorithms they cannot examine
- It is basically the same as the open-source versus compiled software debate that is in full force today.

3.1.3 The Strength of the Cryptosystem

- The ***strength*** *of an encryption method comes from the algorithm, the secrecy of the* key, the length of the key, the initialization vectors, and how they all work together within the cryptosystem.
- When strength is discussed in encryption, it refers to how hard it is to figure out the algorithm or key, whichever is not made public.

- The strength of an encryption method correlates to the amount of necessary processing power, resources, and time required to break the cryptosystem or to figure out the value of the key.
- Breaking a cryptosystem can be accomplished by a brute force attack, which means trying every possible key value until the resulting plaintext is meaningful
- Depending on the algorithm and length of the key, this can be an easy task or one that is close to impossible

- The goal when designing an encryption method is to make compromising it too expensive or too time-consuming
- Another name for cryptography strength is ***work factor,*** which is an estimate of the effort and resources it would take an attacker to penetrate a cryptosystem

- Important elements of encryption are to use an algorithm without flaws, use a large key size, use all possible values within the keyspace, and to protect the actual key.
- If one element is weak, it could be the link that dooms the whole process.

Even if a user employs an algorithm that has all the requirements for strong encryption, including a large keyspace and a large and random key value, if he shares his key with others, the strength of the algorithm becomes almost irrelevant.

3.1.4 Services of Cryptosystems

- Confidentiality
- Integrity
- Authentication
- Authorization
- Nonrepudiation

Services of Cryptosystems

- **Confidentiality**

  Renders the information unintelligible except by authorized entities
- **Integrity**

  Data has not been altered in an unauthorized manner since it was created, transmitted, or stored
- **Authentication**

  Verifies the identity of the user or system that created information
- **Authorization**

  Upon proving identity, the individual is then provided with the key or password that will allow access to some resource
- **Nonrepudiation**

  Ensures that the sender cannot deny sending the message.

If David sends a message and then later claims he did not send it, this is an act of repudiation.

When a cryptography mechanism provides nonrepudiation, the sender cannot later deny he sent the message. (He can try to deny it, but the cryptosystem proves otherwise)

Suppose your boss sends you a message telling you that you will be receiving a raise that doubles your salary.

- The message is encrypted, so you can be sure it really came from your boss (authenticity)
- Someone did not alter it before it arrived at your computer (integrity)
- No one else was able to read it as it traveled over the network (confidentiality)
- Your boss cannot deny sending it later when he comes to his senses (nonrepudiation)

- Military and intelligence agencies are very concerned about keeping information confidential, so they would choose encryption mechanisms that provide a high degree of secrecy
- Financial institutions care about confidentiality, but they also care about the integrity of the data being transmitted, so the encryption mechanism they would choose may differ from the military's encryption methods
- If messages were accepted that had a misplaced decimal point or zero, the ramifications could be far reaching in the financial world

- Legal agencies may care most about the authenticity of the messages they receive
- If information received ever needed to be presented in a court of law, its authenticity would certainly be questioned; therefore, the encryption method used must ensure authenticity, which confirms who sent the information